

Investigating a Lumma Stealer Detection Using Zeek Logs (Evidence-Based Analysis)

Introduction

This article walks through a practical investigation involving a Lumma Stealer detection. Starting from a single intrusion detection system (IDS) alert, we leverage Zeek network logs to identify the compromised endpoint, determine the affected user account, and uncover the malicious infrastructure involved in the attack. The exercise demonstrates how analysts can transform a seemingly simple alert into actionable intelligence for incident responders.

Lumma Stealer is an information-stealing malware family that specializes in collecting sensitive data from infected systems. Before stealing credentials or browser data, the malware often performs victim fingerprinting, gathering information about the operating system, hostname, user account, and environment. This information is transmitted to attacker-controlled infrastructure and helps threat actors determine the value of the compromised system.

Scenario Overview

The investigation begins with a known malicious network indicator:

- Lumma Stealer IP Address: **153.92.1[.]49**
- Port: 443
- Timestamp: 2026-01-27 at 23:05 UTC

Environment Details

- LAN Segment: 10.1.21.0/24
- Gateway: 10.1.21[.]1
- Broadcast: 10.1.21[.]255
- Domain: win11office[.]com
- Active Directory Domain: WIN11OFFICE
- Domain Controller: 10.1.21[.]2 (WIN-LU4L24X3UB7)

Investigation Methodology

The analysis is performed using the following Zeek logs:

- conn.log → Network communication metadata
- dhcp.log → Host identification (MAC address, hostname)
- kerberos.log → Authentication activity
- dns.log → network name lookups

Each conclusion is derived strictly from these logs.

What is the IP address of the infected Windows client?

To determine which internal system is compromised, we will use conn.log to see which all internal systems communicated with the malicious IP address.

Command: `cat conn.log | zeek-cut id.orig_h id.resp_h | grep '153.92.1.49'`

```
id.resp_h | grep '153.92.1.49' | uniq
10.1.21.58      153.92.1.49
```

Infected Host: **10.1.21[.]58**

What is the MAC address of the infected Windows client?

To determine the MAC address of the infected host we will use dhcp.log. Using the already gained information on the infected host we can correlate and get the MAC address.

Command: `cat dhcp.log | zeek-cut mac client_addr`

```
mac      client_addr
00:21:5d:c8:0e:f2      10.1.21.58
```

MAC Address: **00:21:5d:c8:0e:f2**

What is the host name of the infected Windows client?

The hostname is also available in the DHCP logs.

Command: `cat dhcp.log | zeek-cut host_name client_addr`

```
host_name client_addr
DESKTOP-ES9F3ML 10.1.21.58
```

Hostname: **DESKTOP-ES9F3ML**

Combined Extraction (Efficient Approach)

Both MAC address and hostname can be extracted together:

Command: `cat dhcp.log | zeek-cut mac host_name client_addr`

```
name client_addr
00:21:5d:c8:0e:f2      DESKTOP-ES9F3ML 10.1.21.58
```

What is the user account name from the infected Windows client?

To determine which user account was active on the system, we analyze Kerberos authentication logs.

Command: `cat kerberos.log | zeek-cut client | sort | uniq`

```
10.1.21.58      -
10.1.21.58      gwyatt/WIN11OFFICE
10.1.21.58      gwyatt/WIN11OFFICE.COM
```

User Account Name: **gwyatt**

What is the domain from 153.92.1[.]49 that triggered the alert for Lumma Stealer?

To determine the domain from which **153.92.1[.]49** triggered the alert, we can use `dns.log`. We will inspect the query and answers columns of `dns.log` and then `grep` it with the malicious IP address of Lumma Stealer.

Command: `cat dns.log | zeek-cut query answers | grep "153.92.1.49"`

```
153.92.1.49 | grep 153.92.1.49 | zeek-cut query answers | sort | uniq
whitepepper.su 153.92.1.49
```

Domain: **whitepepper[.]su**

Important Note on User Identity

What Can Be Determined

- Username (**gwyatt**)
- Authentication activity patterns

What Cannot Be Determined

Zeek logs do not inherently provide full user identity details, such as:

- Full name
- Display name
- Directory attributes (e.g., LDAP/AD metadata)

Such information is only available if explicitly captured within application-layer logs (e.g., HTTP, FTP). It can be found in deep-inspection tools like Wireshark.

Key Findings

Artifact	Value
Infected Host IP	10.1.21[.]58
MAC Address	00:21:5d:c8:0e:f2
Hostname	DESKTOP-ES9F3ML
User Account	gwyatt
Malicious Domain	whitepepper[.]su
Malicious IP	153.92.1[.]49

Key Takeaways

- Zeek logs provide strong network-level visibility, enabling identification of compromised hosts without endpoint telemetry.
- Correlation across logs (conn, DHCP, Kerberos, DNS) is critical for building a complete picture.
- Evidence-based investigation prevents false assumptions, ensuring accuracy in incident response.
- User attribution is limited without application-layer or directory service logs.

Conclusion

Effective incident response begins with visibility. In this case, a single IDS alert indicating Lumma Stealer activity was enough to uncover a compromised workstation, identify the associated user, and trace communications to attacker-controlled infrastructure. By leveraging Zeek logs and methodically correlating network artifacts, investigators were able to establish attribution quickly and provide responders with the information necessary to contain and remediate the threat.

This investigation serves as a practical example of how network-centric analysis remains one of the most powerful techniques available to SOC analysts when confronting modern malware infections.